CLOUD SECURITY AND SRE · IIIT DHARWAD

ಭಾರತೀಯ ಮಾಹಿತಿ ತಂತ್ರಜ್ಞಾನ ಸಂಸ್ಥೆ ಧಾರವಾಡ
भारतीय सूचना प्रौद्योगिकी संस्थान धारवाड़
Indian Institute of Information Technology Dharwad
[Institute of National Importance by An Act of Parliament]

RuntimeLens

Context-aware runtime and orchestration threat classification for multi-tenant Kubernetes, using a typed-decision model.

"Runtime detection that knows what your workload is supposed to do."

Team Members

Himanshu Kumar 23BCS055

Altaf Raja 23BCS011

Kamal Nayan Kumar 23BDS026

COURSE

Cloud Security and SRE

Instructor: Dr. Malay Kumar

Rules see syscalls. They can’t see intent.

Falco-style tools judge each event alone — no workload context, so real attacks blend in and noise wins.



Alert fatigue

- Falco: Macro-F1 0.333
- Benign FPR 18.4%
- Containment precision 54.2%

report §7.3



Blind to multi-step

- Escape + token theft + egress
- each looks benign alone —
- rules cannot chain them

GCID, 2026 — our motivation



One kernel, many tenants

- Shared kernel + control plane
- one compromised tenant
- spreads laterally

THREAT_MODEL §1 (Jarkas ’25)

Without context → **every maintenance shell looks hostile, so the real one gets ignored.**

Five goals. One pre-registered question.

1 · Pre-registered hypothesis

- H_1: baseline context changes Macro-F1 and/or benign FPR
- Paired ON/OFF comparison, same incidents
- Locked 2026-10-17 — before test split access
- Both outcomes reported as measured

2 · Five-source fusion

- Falco + audit + Hubble + metrics + Trivy → one state

3 · SRE-safe response

- Zero pod-delete RBAC · dry-run · 900 s TTL auto-rollback

4 · Honest measurement

- Cluster bootstrap CIs · McNemar · 4-tier ASR · Holm correction

5 · Reproducible delivery

- 84-run corpus · 282 passing tests · report, paper, demo

NOT IN SCOPE

Pod termination (design-only) · production rollout · ScaleDown token compression (does not exist) · formal SLOs · non-dry-run quarantine

The field — and the gap we fill

Paper / tool	What it does	Gap it leaves
Jarkas et al. · ACM CSUR 2025	5-layer container threat taxonomy (our model)	Taxonomy only — no runtime defense loop
Galletta · arXiv 2026	Stateful in-kernel eBPF security policies	Kernel policy — no workload context
Franzil et al. · Comp. Networks 2026	Sharpens K8s audit logs with context	Audit stream only — no 5-source fusion
Chen et al. · Shadowkube · 2025	Learned baseline + honeypots, closest precedent	No typed decision · no hash-chained audit
Karanjai et al. · arXiv 2026	Context contamination in LLM log analysis	Attack, not a defense — motivates our sanitizer

22-reference bibliography in PROJECT_FOR_PPT.md §19 · taxonomy in THREAT_MODEL §1 · DOIs verified against paper source

Same telemetry. Different outcome.

Existing approach	Limitation	RuntimeLens
Falco default rules	**Macro-F1 0.333 · FPR 18.4%**	**Macro-F1 0.533 · FPR 3.6%**
Random Forest on K8s logs	0.481 dev F1 · heavy feature engineering	Kept as an arm · typed decision on top
LLM triage / SOC agents	Injection-prone · no safe actuation	4-tier defense · ASR 30% → 0.0% · engine final

Macro-F1 / FPR from docs/report/final_report.md §7.3 · ASR from research/results/adversarial_aggregate.md · identical dev budget (ABL design)

Three things we built that don’t exist together

The closed loop

- 5-source eBPF telemetry → declared baseline → typed decision → hash-chained audit → auto-rollback.

No 2022–26 system ships all five.

Honest measurement

- Pre-registered, paired ON/OFF, locked pre-test. +0.0201 ΔMacro-F1 lab; live replication inconclusive — reported anyway.

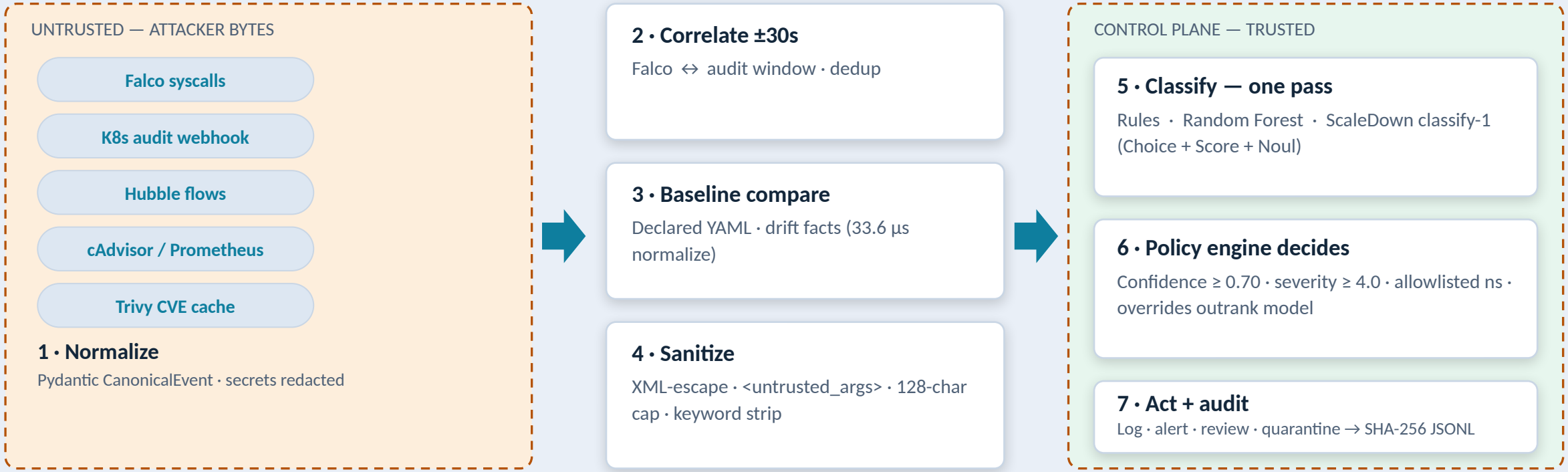
Most course projects stop at the first good number.

Safe by construction

- Dry-run default · zero pod-delete verbs · 900 s TTL rollback · overrides outrank model confidence.

Probabilistic AI, mission-critical infra.

From five streams to one auditable decision



1–5 attacker-controlled input path · 6 deterministic code outranks model confidence · 7 reversible actuation, every decision hash-chained

Latency p50: normalize 33.6 µs → rules 1.9 µs → policy 1.5 µs → audit 85.9 µs · full pipeline diagram: ppt_assets/architecture.png

Pinned stack, no magic

Cloud & infra

kind v0.22.0 · Kubernetes 1.29.2
Cilium 1.20.1 · Falco 0.45.0 (eBPF)
kindest/node v1.29.2 · Ubuntu 24.04 · kernel 6.8

Backend

Python ≥ 3.12 · Pydantic v2
httpx · scikit-learn ≥ 1.4
uv · hatchling · JSON Schema

Models & AI

ScaleDown classify-1 (prod)
Groq: gpt-oss-20b · qwen3.8-27b (A/B)
RF arm · NIM prompt-guards (tier 3)

Security

Namespaced RBAC · zero delete verbs
Default-deny NetworkPolicy · PSA + quotas
Sanitizer · gitleaks · pre-commit

Observability

Prometheus :9090 (15 metrics)
Grafana dashboard.json · tracing: none
JSONL audit · SHA-256 chain · verify_chain()

Every version pinned in pyproject.toml / DECISIONS D-06 · no external services in CI · lab VM: 6–8 GB RAM, 40 GB disk budget

Every threat has a deterministic answer

Threat	Control that answers it
Malicious command line (“ignore previous instructions…”)	Sanitizer — keyword strip · <untrusted_args> wrap · XML escape
Stolen SA token · exec via API server	Namespaced allowlist RBAC — zero delete verbs
hostPath / runtime socket → container escape	Deterministic overrides from pod spec — not model judgment
Cryptomining egress	Hubble + cAdvisor fusion · sustained-CPU fact · tiered response
Baseline poisoning via telemetry	Declared YAML baselines · leakage gate: 0 class tokens in raw data

PRACTICE

- Least privilege
- Zero trust
- Defense in depth
- OWASP LLM01/02
- CIS Pod Security

Measured

ASR **30% → 0.0%**

10 payloads × 4 tiers, 2 reps · full stack neutralizes

All lab endpoints bound to 127.0.0.1 · secrets env-only, CI-scanned · sanitizer redacts before any model call

Measured reliability — honest gaps

7,879.6
events/s
full hash-chained audit · 5×1,000 events · 0 errors

122.6 µs
p50 end-to-end
normalize 33.6 · rules 1.9 · policy 1.5 · audit 85.9 µs

0.00%
errors
5,000 events · every trial · hash chain verified

85.9 µs
audit write (p50)
~70% of pipeline budget — cost of tamper evidence, paid on purpose

Formal SLOs / error budget: not defined — nothing claimed

```
zsh — benchmark_pipeline.py

$ uv run python scripts/benchmark_pipeline.py
5 trials × 1,000 events  ·  errors: 0

throughput  7,879.6 events/s  (median)
p50 latency 122.6 µs
normalize 33.6 µs  rules 1.9 µs  policy 1.5 µs
audit      85.9 µs  (~70% of budget)
audit chain verify_chain ... OK
```

Output trimmed. Numbers from data/benchmarks/latest.json — benchmark screenshot: docs/report/screenshots/03_pipeline_benchmark.png

CI — offline, verify-only

Checkout → Secrets scan → gitleaks → ruff + fmt → mypy → 282 tests ✓

No cluster, no API keys, no network in CI · no CD / blue-green / canary — demo deploys to kind on demand

One state in, three typed answers out

How the LLM is used

- Not chat, not RAG — one serialized incident state, one calibrated decode pass
- classify-1 answers: attack_type (Choice, 5 classes) · severity (Score 0–4) · 4 Noul flags
- Advisory only — the policy engine is the final authority
- Temp 0 · 5.0 s hard timeout → degraded mode → human review

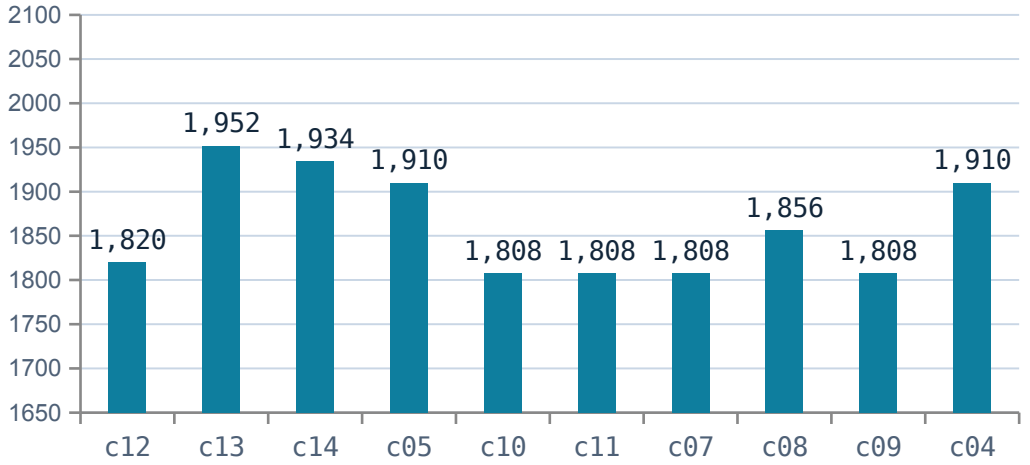
Models

Prod: ScaleDown classify-1 (hosted SLM)

A/B: gpt-oss-20b · qwen3.8-27b (Groq)

Tier 3: Llama Guard 4 + Nemotron safety guard (NIM)

Measured calls — tokens in



$0.000090–0.000098 per call · mean $0.0000931

≈ $0.093 per 1,000 decisions

Pre-filter ON: 99.2% recall · −64.5% API cost (ABL-PREF)

No prompt/token compression in this project — typed-decision classifier only.

Six gates to an honest result

1

Feasibility gate

Kernel / BTF check on Ubuntu 24.04 VM before any code

2

Lab bring-up

kind + Cilium + Falco · 3 tenants × 4 workloads

3

Vertical slice

make demo — 4 scenarios end-to-end, audit verified

4

Corpus capture

84 live runs · 55 templates · zero leakage gate

5

Pre-registration

Locked 2026-10-17 — before test-split access

6

Evaluate & deliver

ABL battery · live A/B · report · paper · this deck

Scope shed first, never the core eval (D-17): human feedback loop → risk score → live quarantine → Grafana panels → Hubble/Trivy normalizers

Mode A pair programming · authors ran and approved every gate · full log: docs/GATE_REPORTS.md (1,556 lines)

Modest where it counts — zero where it matters

0.5333

Macro-F1 (lab, 112-run held-out)

vs 0.3333 Falco · +0.2000

3.6%

benign false-positive rate

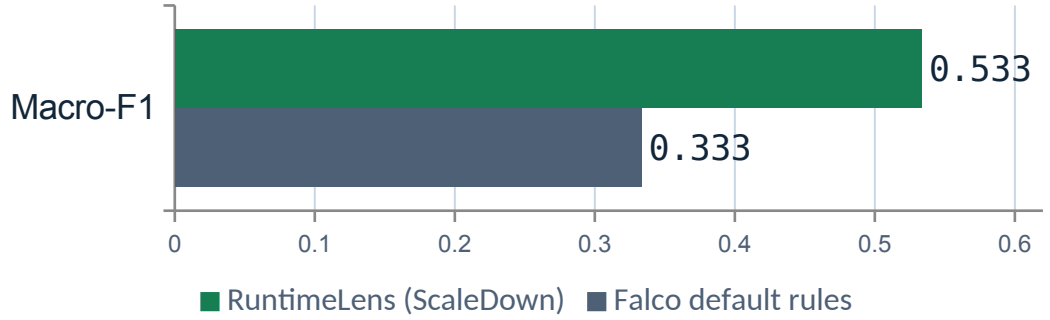
vs 18.4% Falco · −41.7% relative

0.0%

prompt-injection ASR, full stack

from 30.0% raw · all four tiers

Before → after — same telemetry, same evaluation budget



Also measured:

RF 84-run corpus: 0.5603 ± 0.0700 F1 · 4.8% FPR

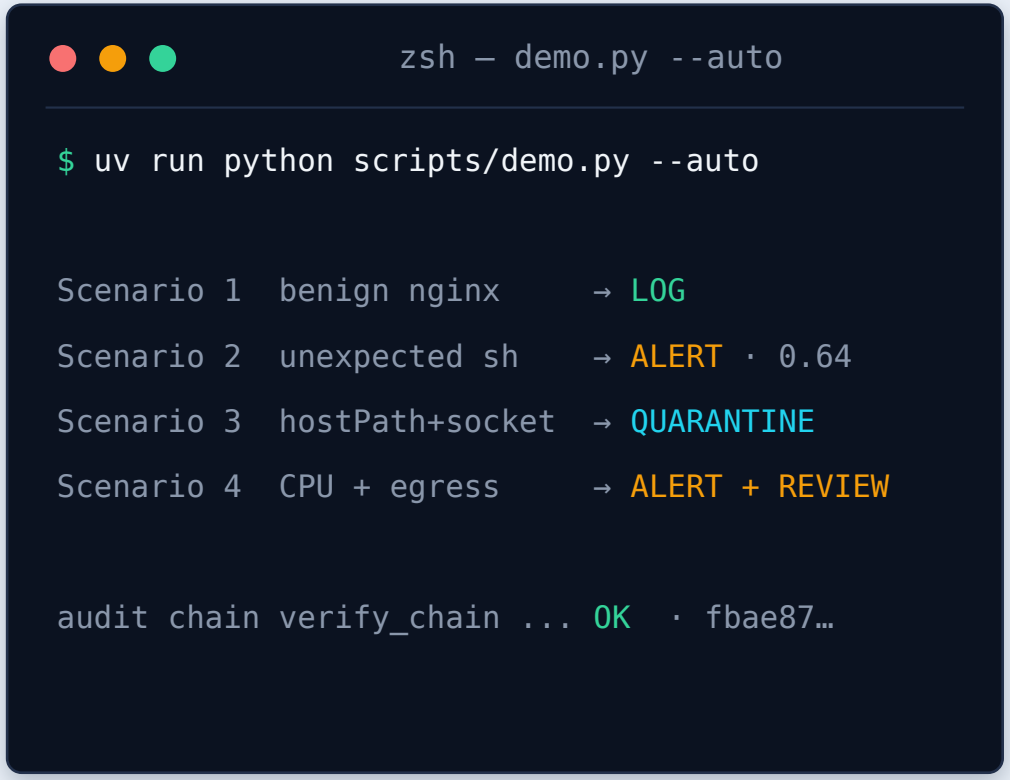
Live A/B (n=28, 2 arms): Macro-F1 inconclusive, FPR halved

Pre-registered Δ +0.0201 [+0.0132, +0.0275]

Sources: docs/report/final_report.md §7 · research/results/live_analysis.md · ablation_study_results.json — reported as measured, including the null.

Five minutes · four scenarios · one proof

1. Benign nginx passes its baseline → action LOG · audit hash-chained
2. Unexpected /bin/sh in database pod → ALERT / human review
3. hostPath + socket (escape) → dry-run NetworkPolicy quarantine
4. Sustained CPU + egress → ALERT + review queue
5. verify_chain + make lab-verify → tamper-evidence proven



Live run — output trimmed. Audit chain verified inline.
Full recording: docs/demo/runtimelens_demo.mp4

What broke — and what ships next

Challenges & limits

- Leakage bug: F1 = 1.0 — tag invalidated, retrained
- Vendor 70–500 ms claim struck; measured ≈ 1.04 s
- ScaleDown 402 credits — live calls capped at 14
- Live macro-F1 inconclusive (n=28) — kept as-is
- Ablation artifact contradicts 0.5333 headline
- Lab-only · data/raw gitignored · no SLOs, no CD
- Docs disagree: 1.2 s vs ±30 s correlation window

Future work

- On-node quantized SLM — telemetry never leaves the pod
- Field trial on a non-lab cluster, pre-registered again
- Scoped SA-token revocation tier — still reversible, zero deletes
- Hubble + Trivy normalizers into the hot path
- Review-queue reclassifications → automatic baseline diffs

Three things to remember

1

Context beats rules

- 0.5333 Macro-F1 · 3.6% benign FPR — vs 0.333 / 18.4% for Falco.

2

Honest beats impressive

- Pre-registered; +0.0201 kept; the live null kept too — nothing tuned after the fact.

3

Safe to run where it matters

- Dry-run · zero delete verbs · 900 s TTL rollback · hash-chained audit.

Thank you

`github.com/himanshukumar19/RuntimeLens` · `PROJECT_FOR_PPT.md` · `docs/GATE_REPORTS.md`

References

- Jarkas et al., ACM Computing Surveys, 2025 — 5-layer container threat taxonomy
- Galletta, arXiv:2609.13930, 2026 — stateful eBPF policies
- Islam & Rashid, 2026 — GCID: rules cannot chain (our motivation)
- Ryu et al., Comput. Mater. Continua 86(3), 2026 — hybrid eBPF detection
- Chen et al., Shadowkube, Cybersecurity, 2025 — closest precedent
- Franzil et al., Comput. Networks 276, 2026 — context-aware audit logs
- Aly et al., OCR-APT, ACM CCS 2025 · Malul et al., GenKubeSec, 2024
- Karanjai et al., arXiv:2607.14493, 2026 — context contamination (our sanitizer)
- Grinsztajn et al., NeurIPS D&B 2022 — why forests beat nets on tabular
- McNemar, Psychometrika 1947 · Holm, Scand. J. Stat. 1979
- ScaleDown AI — Platform docs & Decisions API reference, 2026
- Falco (CNCF) · Cilium/Hubble · Kubernetes · scikit-learn · Prometheus

Every number in this deck traces to a file in the repo.

Full list: PROJECT_FOR_PPT.md §19 — 22 papers · 6 tool references · all DOIs verified in docs/paper/runtimelens_paper.tex